27/8/26

* Case study

1) Brightmart is a medium sized online website. Customer use its website and mobile application to purchase products.

The Company stores :-

- Customer names
- Email addresses
- Phone numbers
- Delivery addresses
- Passwords
- Order information
- Payment - related information.

Brightmart has around 100 employees.

The Company recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

However, the Company has the following security weaknesses :

- Some employees use simple passwords such as Brightmart123

- Many employees use the same password for multiple systems.
- Software updates are sometimes delayed.
- The Company does not regularly conduct employee cybersecurity training
- There is no multi-factor authentication for some important accounts.
- Employees can access sensitive information that they do not necessarily need for their jobs
- Backups are performed only once a month.

The Incident

One monday morning, an employee named Rahul receives an email.

Subject :- Urgent - Your Account will be Suspended

The email appears to come from the company's IT department.
It says:

" Your Company account will be suspended today. Click the link below and verify your password immediately

Rahul clicks the link.

The page looks almost identical to the Company's login page.
He enters his username & password.

Rahul does not realize that the website is controlled by an attacker.

The attacker now has Rahul's login credentials.

Stage 1 - Unauthorized access.

The attacker uses Rahul's credentials to access Brightmark's internal system.

Because Rahul uses the same password for another system, the attacker is also able to access that system.

The attacker discovers that Rahul has access to customer information.

The attacker downloads a large amount of customer data.

Q What cybersecurity problem has occurred?

→
- Phishing
- Credential theft
- Unauthorized access
- Data breach

Stage - 2 - Malware attack

The attacker sends another email to Rahul containing a malicious attachment.
Rahul opens the attachment.
Malware is installed on his computer.

The malware begins communicating with the attacker's system.

The attack now attempts to move from Rahul's computer to other systems within Brightmart's network.

Question

Q Which vulnerability allowed the attacker to move further into the organisation?

→
- Weak passwords
- Excessive user privileges
- Lack of MFA
- Poor network security
- Lack of employee awareness
- Outdated software

Stage 3 - Ransomware

Two days later, employees arrive at work and discover that they cannot access important files.

A message appears on their computers:

"Your files have been encrypted. Pay the ransom to recover them."

The Company's customer database and several important business files are encrypted. Unfortunately, the company's most recent backup is almost a month old.

Brightmart's website Stop working.
Customers cannot place orders.
The Customer - support team cannot access customer records.

Stage 4 - Business Impact

Brightmart now faces several problems.
Financial impact

The Company loses sales because its website is unavailable.

Data Impact.
Customer information may have been stolen.

Operational Impact
Employees cannot access important systems.

Reputation Impact
Customer lose confidence in the company.

legal / Compliance Impact
The company may face regulatory or legal consequences depending on what information was exposed & which laws apply.

Group 1 - Identify the Threats

What threats are present in this case?

→
- Phising
- Malware
- Ransomware
- Credential theft
- Unauthorized access
- Data theft.

Group 2 - Identify the Vulnerabilities

What weaknesses in Brightmart's security allowed the attack to succeed?

→

Vulnerability	How it helped the attacker
Weak passwords	- Easier to compromise accounts.
Password reuse	- One stolen password gives access to multiple systems
No MFA	- Stolen password may be enough to log in
Lack of training	- Employee falls for phishing.
Delayed updates	- Vulnerable software may be exploited
Excessive privileges	- Attacker can access more data
Infrequent backups	difficult to recover after ransom ware.

Group 3 - Apply the CIA Triad

Q Was confidential information exposed?

→ Yes, Customer information was accessed / downloaded by the attacker. Intergrity

Q Was information changed or damaged?

→ Potentially yes.
The attacker could modify or encrypt files.
Availiability

Q Were systems available to legitimate users?
→ No, The website & internal systems became unavailable because of ransonware.
So: Confidentiality → affected
Integrity → Affected
Availability → Affected

Group 4 - Security Solutions

What should Brightmart do to prevent this from happening again?
→ Students could suggest:

- Use strong passwords.
- Implement Multi-Factor Authentication (MFA)
- Provide regular cybersecurity awareness training.
- Conduct phishing-awareness exercises
- Keep software updated.
- Follow the principal of least privileage
- Segment important networks
- Maintain regular backups
- Encrypt sensitive data
- Deploy antivirus / endpoint protection
- Monitor suspicious login activity
- Develop an incident-response plan.

1] Who is responsible for cybersecurity?
→ Not only the IT department. Every employee who uses the organization's systems has a role in cybersecurity.

2] Was phishing the only problem?
→ No.
Phising was the initial attack, but weakness such as password reuse, lack of MFA, excessive privileges, poor backups, and insufficient training allowed the attacker to become much more damaging.

3] What was the biggest vulnerability?
→ There is no single correct answer.
For eg -
"Lack of employee awareness was a major vulnerability because the attack started when Rahul clicked the phising link."

~~Ans~~ "Poor backup practices were the biggest problem because Brightmart could not quickly recover from from ransomware."